



State of Ohio Administrative Policy

Data Encryption and Securing Confidential Data

No: IT-14

Information Technology

Effective:

April 29, 2025

Issued By:

Kathleen C. Madden, Director

I. Purpose

This policy, in conjunction with Ohio IT Standard ITS-SEC-01/Data Encryption and Cryptography (ITS-SEC-01), provides guidance to Agencies as they take steps to protect **Confidential Data** and **Information**. Additionally, this policy addresses Agency **Encryption** practices for the security of **Records** that are potentially subject to an investigatory effort. The first occurrence of a defined term in the policy is in bold, italic type, and is hyperlinked to the definition in Section IV.

II. Scope

This policy applies to all Agencies, boards, and commissions under the authority of the Governor (collectively referred to as Agency or Agencies).

III. Policy

It is critical that Agencies implement the appropriate safeguards to protect Confidential Data and Information. This policy outlines the requirements for identifying and securing Confidential Data as well as the **Portable Devices** and **Media** on which Confidential Data resides.

- A. **Identify and Label Confidential Data:** Agencies must classify **Data**, systems, Media, Portable Devices and electronic transmissions and establish procedures to identify, label and secure Data in accordance with Ohio Administrative Policy IT-13/Data Classification, and the accompanying Ohio IT Standard ITS-SEC-04/Data Classification.
- B. **Use Only State-Approved Strong Encryption:** Any use of Encryption to protect Confidential Data must conform to ITS-SEC-01. Agencies must ensure that a cryptographic key management plan is in place that protects the creation, distribution and storage of

cryptographic keys as described by National Institute of Standards and Technology (NIST) Special Publication (SP) 800-57, “Recommendation for Key Management, Parts 1, 2, and 3.”

C. **Secure Confidential Data in Transmission:** Agencies must secure Confidential Data in transmission. Whenever Confidential Data travels over the Internet or other untrusted channels, as a minimum, Encryption must be used to safeguard the Data.

1. In particular, the following forms of transmission over untrusted channels must be Encrypted:
 - a) e-mail;
 - b) pages on state-controlled websites;
 - c) instant messaging;
 - d) remote printing;
 - e) Data transfers;
 - f) copying of Data to removable Media; and
 - g) any wireless transmission.
2. Agencies must establish a process to check Data in transmission for activities that risk unauthorized access to or disclosure of Confidential Data. There are different means of checking for these types of activities, and they include increased activity logging, spot audits, the use of content monitoring, and lexical analysis tools among others.

D. **Secure Confidential Data at Rest:** Agencies must secure Confidential Data at rest. Regardless of whether access is via trusted or untrusted channels, Agencies must provide strong **Access Controls** for Confidential Data at rest. As a minimum, Agencies must protect Confidential Data at rest through Encryption. The following Agency practices must be in place to secure access to Confidential Data systems:

1. Implement restrictions on the downloading of Confidential Data.
2. Apply authorization controls so that individual access is limited to a need-to-know basis based on the **User's** role in the Agency.
3. Employ a session lock for accounts, including those initiated via remote access or Portable Devices, that requires re-authentication after no more than 30 minutes of inactivity.
4. Implement a process for prompt deactivation of accounts for Users who are no longer employed, must no longer have access, or are subject to an action requiring deactivation.
5. Conduct a regular validation of User accounts to ensure that access rights are assigned, as appropriate.

- E. **Secure Backups:** In performing Confidential Data backups and restorations, Agencies must ensure:
1. Encryption is consistently applied to backup Portable Devices, Media and active Data.
 2. Data backups enforce the most current Access Controls.
 3. Reuse of backup Media is limited to the same set of Confidential Data or is securely sanitized in accordance with NIST SP 800-88, "Guidelines for Media Sanitization," (NIST SP 800-88) if it is used for another purpose.
 4. Backup Media is destroyed in accordance with NIST SP 800-88 guidelines once it is no longer necessary.
 5. Appropriate physical security controls must be in place, including:
 - a) Physical access to backups of Confidential Data must be limited to authorized personnel only.
 - b) Physical transportation of backup Media must be secure.
 - (i) Transport must be provided by a state employee or state-approved secure carrier.
 - (ii) When possible, backup Media must be transported using a locked, tamper proof box to secure the Media.
 - c) Physical storage of Confidential Data backups and restorations must be located at a state-owned or state-approved, secure facility.
- F. **Secure Confidential Data on Portable Devices and Media:** At a minimum, Agencies must implement the following controls for the placement of Confidential Data on Portable Devices and Media:
1. A procedure must be developed for authorizing the placement of Confidential Data onto Portable Devices and Media. The procedure must include the following:
 - a) A required ***Risk Assessment*** that will assist in determining the level of ***Risk*** associated with the use of a given Portable Device or type of Media.
 - b) Written authorization for the placement of Confidential Data on Portable Devices and Media.
 - c) Written acknowledgement from each User that he/she agrees to comply with the security requirements of this policy, state IT security policies and Agency IT security policies.
 2. The use of Encryption and strong passwords must be used to protect Confidential Data on Portable Devices and Media. Encryption may be employed at the Data-level, file-level, or operating system.
 3. A procedure must be developed for the removal or destruction of Confidential Data on Portable Devices and Media that aligns with NIST SP 800-88, and the requirements

outlined in Ohio Administrative Policy IT-05/Disposal, Servicing and Transfer of IT Equipment.

4. Agencies must prohibit the placement of Confidential Data on Portable Devices not owned, provided, or controlled by the state.
- G. **Physically Secure Confidential Data:** Agencies must secure the physical Portable Devices, locations, and facilities used for Confidential Data processing and storage.
1. Only authorized personnel must be allowed to access or remove Portable Devices and Media containing Confidential Data.
 2. Under no circumstances must unencrypted Confidential Data be stored or transported in a manner that is not physically secure. For unencrypted Confidential Data, "physically secure" means implementing multiple layers of physical security that use facilities and services designed for securing high Risk Data and certifying that the facilities or services take the necessary physical security precautions.
- H. **Communicate Expectations for Handling Confidential Data:** Agencies must ensure that Users are aware of all of the requirements associated with the protection of Confidential Data and that they actively acknowledge their role. Agencies must require Users to agree in writing to take precautions to protect Confidential Data. The written agreement must include the following:
1. Everyone has a duty to protect Confidential Data.
 2. Confidential Data must not be disclosed without authorization.
 3. Access to Confidential Data must not be provided without proper authorization.
 4. Confidential Data must not be stored on Portable Devices that are personally-owned or otherwise not controlled by the state.
 5. There is no expectation of privacy when using state Portable Devices. The state has the right to access, inspect, and monitor any state Portable Device or service, including any files on or communications through state Portable Devices or services.
 6. The penalties associated with violating the agreement.
- I. **Be Prepared to Respond to an Information Security and Privacy Incident:** Agencies must develop incident response procedures that specifically address a compromise or exposure of Confidential Data and align with Ohio Administrative Policy IT-18/Information Security & Privacy Incident Response. Agency incident response procedures must include a plan to notify and respond to the persons affected.

- J. **Investigations and Data Encryption:** In the context of an investigation, Agencies must provide access to Encrypted Information to law enforcement or other investigatory agents upon a legally authorized request for a search or electronic monitoring. Agencies must establish procedures to support the following actions prior to and upon presentation of a request to access Encrypted Information.
1. Only Use Encryption Solutions that Permit Key Recovery: Except in situations where Encryption is used to **Tokenize** or **Anonymize** Data (e.g., Data analytics), Agencies must maintain cryptographic keys in such a manner that the investigatory Agency may confidentially access any Encrypted Data. The solution must contain a key management component that allows for a highly restricted secondary means of access to Encrypted Information.
 2. Develop and Document Secure Encryption and Encryption Key Management Practices: Agencies must develop Encryption practices consistent with State of Ohio IT policies and standards, including IT Standard ITS-SEC-01. Both physical and logical controls must be used to secure cryptographic keys and access to keys must be logged. The compromise of a system storing cryptographic keys can potentially compromise all cryptographic protections used in an Agency. Therefore, such systems must be treated as higher-impact targets. To ensure access to Encrypted Records is possible, Agencies must maintain cryptographic keys for Records in accordance with the relevant retention schedule of the Record being Encrypted. Agencies must thoroughly document their Encryption practices and secure this documentation accordingly. Agencies must also ensure that backup and recovery of cryptographic keys are a part of the Agency's **Continuity of Operations Plan**.
 3. Designate Encryption Points-of-Contact: The Agency chief Information officer, or designee, must have access to cryptographic keys and must serve as an Encryption point-of-contact. In addition, the Agency must appoint one or more Encryption points-of-contact who must have access to cryptographic keys. Agencies must subject all personnel with access to system assets to a vetting process commensurate with the system assets' Risk Assessment. Personnel with access to cryptographic keys or Confidential Information require thorough vetting.
 4. Identify and Authenticate the Investigator and the Request: The Agency Encryption point-of-contact must consult Agency legal counsel to validate requests for Records or Information, including subpoenas, warrants, and investigatory requests.
 - a) A request, subpoena, or warrant to access a computer, removable Media, or other IT asset includes by definition the means to access all Information on the IT asset, including Encrypted Information. If the Agency chief information officer is the subject of the investigation, the investigatory Agency must forward the request to another Agency Encryption point-of-contact.

- b) The cryptographic key must not be released unless such action is specifically ordered in the subpoena.
- 5. Identify the Target Data: The investigatory Agency and the Agency that received the request must identify the Information necessary to fulfill the request, such as whether the request applies to Data associated with a particular User, Portable Device, or a defined time period. Agencies must limit access to only those Records specified in the request.

IV. Definitions

- A. Access Controls. Process of granting or denying specific requests: 1) for obtaining and using Information and related Information processing services; and 2) to enter specific physical facilities.¹
- B. Anonymize. A process that removes the association between the identifying Dataset and the Data subject.²
- C. Availability. Ensuring timely and reliable access to and use of information.³
- D. Confidential Data. This classification includes Data that is required to be protected by law or regulation, is intended for confidential use, and may not be copied or removed from an agency's operational control without authorized permission. This classification includes Data that, if compromised, may result in loss of life, serious injury, or other harm to an individual or group, or disruption to critical agency operations.
- E. Confidentiality. Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.⁴
- F. Continuity of Operations Plan (COOP). The documentation of a predetermined set of instructions or procedures that describe how an organization's Mission Essential Functions will be sustained during and after a significant disruption.⁵ The COOP is also commonly referred to as a business continuity plan.
- G. Data. Coded representation of quantities, objects and actions. The word, "Data," is often used interchangeably with the word, "Information."

¹ FIPS 201-2, Personal Identity Verification (PIV) of Federal Employees and Contractors. Federal Information Processing Standards Publication (FIPS) September 2013. <<https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.201-2.pdf>>.

² "National Institute of Standards and Technology Internal Report 8053, De-Identification of Personal Information," U.S. Department of Commerce National Institute of Standards and Technology, October 2015, <<https://nvlpubs.nist.gov/nistpubs/ir/2015/NIST.IR.8053.pdf>>.

³ "NIST Special Publication 800-53 Revision 5, Security and Privacy Controls for Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, September, 2020 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>>.

⁴ *Ibid.*

⁵ Swanson, Marianne, Pauline Bowen, Amy Wohl Phillips, Dean Gallup, David Lynes. "NIST Special Publication 800-34 Rev. 1, Contingency Planning Guide for Federal Information Systems," U.S. Department of Commerce National Institute of Standards and Technology, May 2010 <<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-34r1.pdf>>.

- H. Denial-of-Service (DoS). The prevention of authorized access to resources or the delaying of time-critical operations. (Time-critical may be milliseconds or it may be hours, depending upon the service provided.)⁶
- I. Encryption. The use of an algorithmic process to transform Data into a form in which there is a low probability of assigning meaning without use of a confidential process or key.
- J. Information. Data processed into a form that has meaning and value to the recipient to support an action or decision. “Information” is often used interchangeably with “Data.”
- K. Information Security and Privacy Incident (Security Incident). An occurrence that actually or potentially jeopardizes the **Confidentiality, Integrity** or **Availability** of state Information resources. Privacy incidents are a subset of Security Incidents. Examples of Security Incidents include Ransomware, exfiltration of Data, **Denial-of-Service**, account compromise, loss or theft of a computing or Data storage device, improper usage or access, **Information Spillage**, and successful **Social Engineering**.
- L. Information Spillage. Instances where information is placed on systems that are not authorized to process such information. Information spills occur when information that is thought to be a certain classification or impact level is transmitted to a system and subsequently is determined to be of a higher classification or impact level.⁷
- M. Integrity. Guarding against improper information modification or destruction and includes ensuring information non-repudiation and authenticity.⁸
- N. Media. Any device that is capable of storing Information. Media is not required to be capable of processing Information. This definition includes, but is not limited to, the following:
 - 1. external/removable hard drives;
 - 2. magnetic tapes;
 - 3. Portable Devices;
 - 4. optical Media such as compact disks (CDs), digital video disks (DVDs), etc.; and
 - 5. thumb drives (USB keys).
- O. Portable Devices. Computer or device designed for mobile use. A Portable Device includes laptops, smartphones or tablets.
- P. Records. As defined in Section 149.011 of the Ohio Revised Code (ORC).
- Q. Risk. A measure of the extent to which an entity is threatened by a potential circumstance or event, and typically a function of: (1) the adverse impacts that would arise if the circumstance

⁶ “Nieves, Michael, Kelley Dempsey, Victoria Yan Pillitteri, “NIST Special Publication 800-12 Revision 1, An Introduction to Information Security,” U.S. Department of Commerce National Institute of Standards and Technology, June 2017 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-12r1.pdf>>.

⁷ “NIST Special Publication 800-53 Revision 5, Security and Privacy Controls for Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, September, 2020, <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>>.

⁸ *Ibid.*

or event occurs; and (2) the likelihood of occurrence.⁹

- R. Risk Assessment. The process of identifying Risks to organizational operations (including mission, functions, image, reputation), organizational assets, individuals, other organizations, and the state, resulting from the operation of a system.¹⁰
- S. Social Engineering. An attempt to trick someone into revealing information (e.g., a password) that can be used to attack systems or networks.¹¹
- T. Tokenize. Refers to a process by which a piece of Confidential Data, such as a credit card number, is replaced by a non-Confidential value known as a token. The security of a tokenization approach depends on the security of the Confidential Data.¹²
- U. User. An individual or (system) process authorized to access an Information system.¹³

V. Authority

ORC 125.18, 149.11, 1347.12

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final
NIST Special Publication 800-57, Recommendation for Key Management, Parts 1, 2, and 3	Part 1: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-57pt1r5.pdf Part 2: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-57pt2r1.pdf

⁹ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

¹⁰ “NIST Special Publication 800-53 Revision 5, Security and Privacy Controls for Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, September, 2020, <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>>.

¹¹ Cichonski, Paul, Tom Millar, Tim Grance, Karen Scarfone, “National Institute of Standards and Technology Special Publication 800-61 Rev. 2 Computer Security Incident Handling Guide,” U.S. Department of Commerce National Institute of Standards and Technology, August, 2012 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>>.

¹² “Tokenization.” Def. The Gartner Glossary of Information Technology Acronyms and Terms. 2019 Gartner, Inc. and/or its Affiliates. <<https://www.gartner.com/it-glossary/tokenization>>.

¹³ “FIPS 200, Minimum Security Requirements for Federal Information and Information Systems.” U.S. Department of Commerce National Institute of Standards and Technology, March 2006. <<https://csrc.nist.gov/publications/fips/fips200/FIPS-200-final-march.pdf>>.

Document Name	Location
	Part 3: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-57Pt3r1.pdf
NIST Special Publication 800-88, Guidelines for Media Sanitization	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-88r1.pdf
Ohio Administrative Policy IT-05/Disposal, Servicing and Transfer of IT Equipment	https://das.ohio.gov/technology-and-strategy/policies/it-05
Ohio Administrative Policy IT-13/Data Classification	https://das.ohio.gov/technology-and-strategy/policies/it-13
Ohio Administrative Policy IT-18/Information Security & Privacy Incident Response	https://das.ohio.gov/technology-and-strategy/policies/IT-18
Ohio IT Standard ITS-SEC-01/Data Encryption and Cryptography	https://das.ohio.gov/technology-and-strategy/policies/its-sec-01-Data-encryption-and-cryptography
State of Ohio IT Standard ITS-SEC-04/Data Classification	https://ohid.ohio.gov/wps/myportal/gov/myohio/my-resources/oisp/oisp-services/information-security-privacy-standards/its-sec-04-data-classification

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 39th Floor
Columbus, Ohio 43215

1-614-644-6860 | state.isp@das.ohio.gov

State of Ohio Administrative Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy must be reviewed no less than every two years and updated as needed.

Date	Description of Change
07/25/2007	Original Policy.
07/01/2015	Converted Ohio IT Bulletin ITB-2007.02, "Data Encryption and Securing Confidential Data," into an Ohio Administrative Policy. Ohio IT Bulletin ITB-2007.02 is now Ohio Administrative Policy IT-14. Added requirements to ensure alignment with NIST special publications related to key management and Media sanitization. Included new physical security requirements related to the transportation of backup Media. Added a reference to the new Ohio Administrative Policy IT-13, "Data Classification."
07/22/2021	Updated the policy template to reflect the DAS director change.
02/10/2022	Requirements from Ohio IT Bulletin ITB-2008.01, "Encryption and Investigatory Needs," were merged into this policy. Updates were also made to align with the current template, terminology and security practices.
09/05/2023	Updated the policy template. Added revision history review frequency statement.
04/29/2025	Updated to reflect a change in terminology based on the publication of a revision to Ohio Administrative Policy IT-13/Data Classification.